

Progetto Malware Analysis M6

Daniele Atzori

Malware Analysis

Il Malware da analizzare è nella cartella Build_Week_Unit_3 presente sul desktop della macchina virtuale dedicata.

Analisi statica

Con riferimento al file eseguibile Malware_Build_Week_U3, rispondere ai seguenti quesiti utilizzando i tool e le tecniche apprese nelle lezioni teoriche:

- Quanti parametri sono passati alla funzione Main()?
- Quante variabili sono dichiarate all'interno della funzione Main()?
- Quali sezioni sono presenti all'interno del file eseguibile? Descrivete brevemente almeno 2 di quelle identificate
- Quali librerie importa il Malware? Per ognuna delle librerie importate, fate delle ipotesi sulla base della sola analisi statica delle funzionalità che il Malware potrebbe implementare. Utilizzate le funzioni che sono richiamate all'interno delle librerie per supportare le vostre ipotesi.

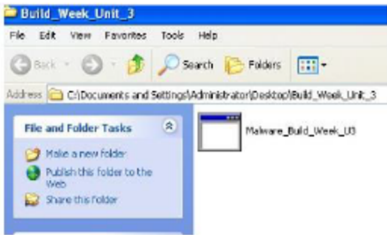
Con riferimento al Malware in analisi, spiegare:

- ☐ Lo scopo della funzione chiamata alla locazione di memoria **00401021**
- ☐ Come vengono passati i parametri alla funzione alla locazione **00401021**;
- ☐ Che oggetto rappresenta il parametro alla locazione **00401017**
- ☐ Il significato delle istruzioni comprese tra gli indirizzi **00401027** e **00401029**.
- ☐ Con riferimento all'ultimo quesito, tradurre il codice Assembly nel corrispondente costruito C.
- ☐ Valutate ora la chiamata alla locazione **00401047**, qual è il valore del parametro «ValueName»?

Malware Analysis

Analisi dinamica

Preparate l'ambiente ed i tool per l'esecuzione del Malware (suggerimento: avviate principalmente Process Monitor ed assicurate di eliminare ogni filtro cliccando sul tasto «reset» quando richiesto in fase di avvio). Eseguite il Malware, facendo doppio click sull'icona dell'eseguibile



Malware Analysis

- Cosa notate all'interno della cartella dove è situato l'eseguibile del Malware? Spiegate cosa è avvenuto, unendo le evidenze che avete raccolto finora per rispondere alla domanda

Analizzate ora i risultati di Process Monitor (consiglio: utilizzate il filtro come in figura sotto per estrarre solo le modifiche apportate al sistema da parte del Malware). Fate click su «ADD» poi su «Apply» come abbiamo visto nella lezione teorica.



Malware Analysis

Filtrate includendo solamente l'attività sul registro di Windows.

- Quale chiave di registro viene creata?
- Quale valore viene associato alla chiave di registro creata?

Passate ora alla visualizzazione dell'attività sul file system.

- Quale chiamata di sistema ha modificato il contenuto della cartella dove è presente l'eseguibile del Malware?

Unite tutte le informazioni raccolte fin qui sia dall'analisi statica che dall'analisi dinamica per delineare il funzionamento del Malware.

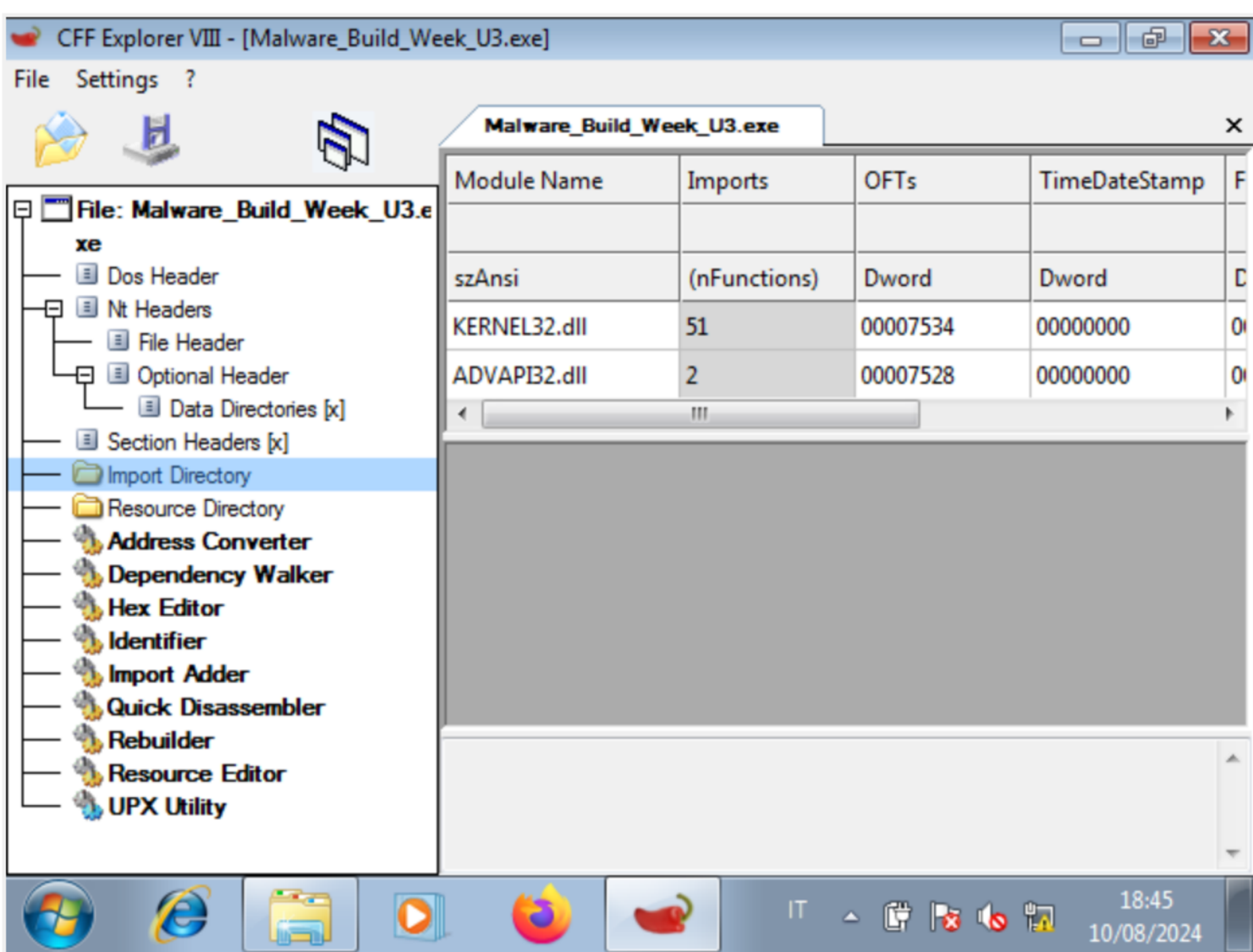
Analisi statica

L'analisi statica di un malware è il processo di esaminare un file sospetto senza eseguirlo, per comprendere il suo comportamento e le sue funzionalità. Questa tecnica implica la disassemblazione o la decompilazione del codice per analizzare l'architettura, le librerie utilizzate, le chiamate di sistema, e le stringhe incorporate. Gli strumenti comuni utilizzati nell'analisi statica includono disassemblatori (come IDA Pro) e strumenti di analisi delle stringhe. L'obiettivo principale è identificare i potenziali obiettivi del malware, come i file o i registri che potrebbe modificare, senza attivare il codice dannoso.

L'analisi statica è particolarmente utile per rilevare indicatori di compromissione (IOC) e ottenere una comprensione preliminare del malware prima di eseguire un'analisi più approfondita. Tuttavia, questa tecnica ha delle limitazioni, soprattutto contro il malware offuscato o criptato, che può nascondere il suo vero comportamento fino a quando non viene eseguito. In questi casi, l'analisi dinamica, che prevede l'esecuzione controllata del malware in un ambiente sicuro, è necessaria per completare il quadro.

In questo caso useremo CFF Explorer, EXEINFOPE e IDAPRO.

CFF Explorer



All'interno di CFF Explorer, accedendo alla sezione "Import Directory", è possibile visualizzare le librerie e le funzioni che il malware importa. Nella sezione "Section Headers" invece, è possibile esplorare le diverse sezioni che compongono il file eseguibile.

Le sezioni chiave includono:

- .text: Contiene le istruzioni di codice che la CPU eseguirà quando il malware viene avviato.
- .rdata: Questa sezione raccoglie le informazioni relative alle librerie e alle funzioni importate ed esportate dall'eseguibile, dati che il programma legge durante la sua esecuzione.
- .data: Comprende i dati e le variabili globali dell'eseguibile, accessibili e modificabili da qualsiasi parte del programma.
- .rsrc: Contiene le risorse utilizzate dall'eseguibile, come icone, immagini, menu e stringhe, che non fanno parte del codice eseguibile stesso.

CFF Explorer VIII - [Malware_Build_Week_U3.exe]

File Settings ?

Open

File: Malware_Build_Week_U3.exe

Dos Header

Nt Headers

File Header

Optional Header

Data Directories [x]

Section Headers [x]

Import Directory

Resource Directory

Address Converter

Dependency Walker

Hex Editor

Identifier

Import Adder

Quick Disassembler

Rebuilder

Resource Editor

UPX Utility

Malware_Build_Week_U3.exe

Name	Virtual Size	Virtual Address	Raw Size	Raw Add
Byte[8]	Dword	Dword	Dword	Dword
.text	00005646	00001000	00006000	00001000
.rdata	000009AE	00007000	00001000	00007000
.data	00003EA8	00008000	00003000	00008000
.rsrc	00001A70	0000C000	00002000	0000B000

Offset

0

1

2

3

4

5

6

7

8

9

A

B

C

18:46

10/08/2024

Considerando le due librerie importate, kernel32.dll e advapi32.dll, si può ipotizzare che il malware stia tentando di ottenere persistenza nel sistema e di modificare le chiavi di registro. Le funzioni come RegSetValueExA e RegCreateKeyExA suggeriscono che il malware potrebbe voler creare o modificare chiavi di registro per garantirsi l'esecuzione automatica ad ogni avvio del sistema. Questo comportamento è tipico di molti malware che cercano di stabilirsi in modo permanente all'interno del sistema compromesso.

Inoltre, la presenza di funzioni come SizeofResource, LockResource, LoadResource, e FindResourceA indica la possibilità che il malware funzioni come un dropper. Un dropper è un tipo di malware progettato per trasportare e rilasciare altri componenti malevoli all'interno del sistema target. Le API sopra menzionate vengono utilizzate per individuare all'interno della sezione ".rsrc" (risorse) del file eseguibile, un payload nascosto, cioè un altro malware incorporato. Una volta localizzato, il dropper utilizza queste funzioni per estrarre il payload dalla sezione delle risorse e caricarlo in memoria, preparandolo per l'esecuzione. Questo metodo permette al malware di nascondere ulteriori componenti malevoli all'interno del suo stesso eseguibile, rendendo più difficile la loro individuazione e analisi da parte dei sistemi di sicurezza.

La combinazione di queste caratteristiche fa presumere che il malware in questione non solo si assicura un accesso continuo al sistema compromesso, ma funge anche da veicolo per ulteriori attacchi, distribuendo altri componenti malevoli che possono eseguire azioni dannose aggiuntive.

EXEINFOPE

Anche in questo caso ci viene confermato l'utilizzo delle due librerie viste precedentemente

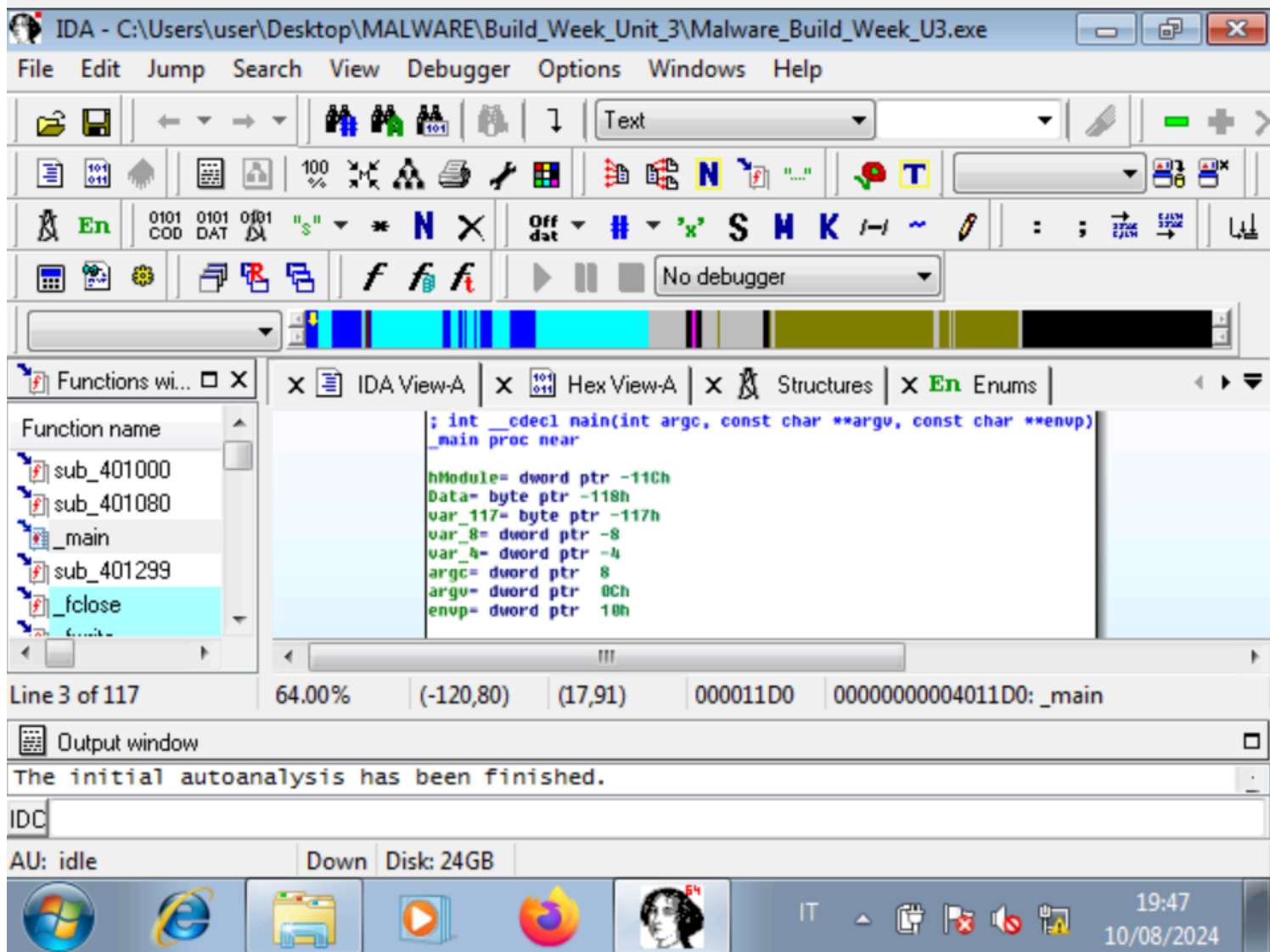
IDA PRO

IDA Pro è uno dei disassembler e debugger più avanzati e utilizzati nell'analisi del software e del malware. Il suo principale scopo è quello di trasformare il codice macchina binario, che è difficile da comprendere per gli esseri umani, in un formato di assembly leggibile. Questo processo consente agli analisti di esplorare il comportamento interno di un programma, identificare funzioni, variabili e flussi di controllo, e capire come un software opera a livello più profondo. È particolarmente utile per il reverse engineering, poiché consente agli esperti di esaminare il codice di programmi sconosciuti o sospetti senza doverli eseguire.

IDA Pro non si limita a disassemblare il codice, ma offre anche funzionalità di debugging che permettono di eseguire il codice in un ambiente controllato e osservare il suo comportamento in tempo reale. Questo è fondamentale per l'analisi del malware, poiché consente agli analisti di studiare come un malware si comporta all'interno di un sistema operativo, quali funzioni chiama, quali dati manipola, e come interagisce con l'ambiente circostante. Grazie a queste capacità, IDA Pro è diventato uno strumento essenziale per gli specialisti di sicurezza informatica, programmatori e chiunque si occupi di analisi del software a basso livello.

- **Parametri:** Sono i dati che vengono passati a una funzione dall'esterno, generalmente durante la chiamata alla funzione stessa. Nel codice assembly, i parametri vengono solitamente passati attraverso i registri della CPU o tramite lo stack. In IDA Pro, i parametri vengono spesso visualizzati nella parte iniziale della funzione, e possono essere identificati con nomi come `arg\_0`, `arg\_1`, ecc., a seconda della convenzione di chiamata utilizzata. Questi parametri sono utilizzati dalla funzione per eseguire operazioni sui dati forniti. In questo caso i parametri che possiamo vedere sono: **argc** **argv** e **envp**.

- **Variabili locali:** Sono variabili definite e utilizzate all'interno di una funzione per memorizzare temporaneamente dei dati durante l'esecuzione della funzione stessa. Queste variabili sono allocate nello stack della funzione e vengono rilasciate una volta che la funzione termina la sua esecuzione. In IDA Pro, le variabili locali sono spesso indicate con nomi come `var\_4`, `var\_8`, ecc., e possono essere utilizzate per tenere traccia di stati intermedi, risultati parziali, o per memorizzare dati temporanei necessari per l'elaborazione della funzione. In questo caso le variabili locali che possiamo vedere sono: **hmodule**, **data**, **var_117**, **var_8** e **var_4**.



Proseguendo con l'analisi statica del malware tramite IDA Pro, ci imbattiamo nella funzione `RegCreateKeyExA` alla locazione di memoria `00401021`. Questa funzione è parte delle API di Windows, un insieme di funzioni di sistema che permettono alle applicazioni di interagire direttamente con il registro di Windows. `RegCreateKeyExA` è utilizzata per creare nuove chiavi di registro o per aprire chiavi esistenti, consentendo così la modifica dei loro valori. Nel contesto di un malware, questa funzione può essere sfruttata per ottenere persistenza all'interno del sistema compromesso. Il malware potrebbe, ad esempio, creare una nuova chiave di registro o modificare una chiave esistente per assicurarsi che il codice malevolo venga eseguito ogni volta che il sistema viene avviato. Un caso comune è l'aggiunta di una voce nella chiave `Run`, che garantisce l'esecuzione automatica del malware ad ogni avvio del sistema operativo.

Per quanto riguarda il metodo di passaggio dei parametri alla funzione `RegCreateKeyExA`, è importante notare che nella maggior parte dei sistemi operativi basati su architettura x86, la convenzione di chiamata prevede che i parametri vengano "pushati" (ovvero, inseriti) nello stack prima della chiamata vera e propria alla funzione (con l'istruzione `CALL`). In questo modo, la funzione può leggere i parametri dallo stack in ordine inverso rispetto a quello in cui sono stati inseriti, iniziando da `hKey` fino a `lpSecurityAttributes`.

```
00401017: .text:00401017      push    offset SubKey
```

In questo scenario, la locazione di memoria 00401017 mostra l'istruzione PUSH offset subkey, che carica nello stack l'indirizzo della sottochiave di registro che il malware intende manipolare. Questo potrebbe indicare che il malware sta tentando di creare o modificare una sottochiave all'interno del contesto HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run, il che gli consentirebbe di eseguire il codice malevolo ogni volta che l'utente accede al sistema.

```
00401027: .text:00401027      test     eax, eax
00401029: .text:00401029      jz       short loc_401032
```

Per quanto riguarda il significato delle istruzioni presenti tra gli indirizzi 00401027 e 00401029, si osserva un'istruzione condizionale TEST. Questa istruzione è simile a un'operazione di AND logico bit a bit, ma differisce per il fatto che non modifica il contenuto degli operandi. Invece, modifica il flag ZF (Zero Flag) del registro EFLAGS. ZF viene impostato a 1 solo se il risultato dell'operazione AND è zero. Ad esempio, se l'operazione TEST coinvolge due registri e il risultato è zero (come nel caso di 0 AND 1), ZF verrà settato a 1. Questa operazione è utilizzata per verificare se un determinato valore è zero o meno. Se il valore testato è zero, ZF sarà 1.

Subito dopo, troviamo l'istruzione JZ (Jump if Zero), che è un salto condizionale. Questa istruzione controlla il valore di ZF: se ZF è pari a 1, il flusso di esecuzione del programma salterà all'indirizzo di memoria specificato, in questo caso 00401032. Tuttavia, se il valore contenuto nel registro EAX non è zero, il salto non avverrà e il programma continuerà l'esecuzione lineare. Questo tipo di controllo è essenziale per gestire le condizioni e determinare il flusso esatto dell'esecuzione del codice, specialmente in scenari complessi come quelli gestiti da malware.

```
00401021: .text:00401021      call     ds:RegCreateKeyEx
```

Alla locazione 00401021 del codice, viene eseguita una chiamata alla funzione RegCreateKeyExA, una funzione delle API di Windows utilizzata per interagire con il registro di sistema. Il registro di Windows è un database centrale che memorizza configurazioni, impostazioni e altre informazioni vitali per il funzionamento del sistema operativo e delle applicazioni. La funzione RegCreateKeyExA consente a un programma di creare una nuova chiave di registro o aprire una chiave esistente, restituendo un handle che permette al programma di leggere o scrivere dati all'interno di quella chiave.

Nel contesto di un malware, l'uso di RegCreateKeyExA è spesso legato a scopi malevoli, come ottenere persistenza o modificare configurazioni critiche del sistema. Creando o modificando chiavi di registro specifiche, il malware può assicurarsi che venga eseguito automaticamente ad ogni avvio del sistema, inserendosi in chiavi come `HKEY\_LOCAL\_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run`. Inoltre, può alterare configurazioni che rendono più difficile la sua rimozione o disabilitare funzioni di sicurezza del sistema operativo.

Il passaggio dei parametri alla funzione RegCreateKeyExA avviene tramite lo stack. I principali parametri includono l'handle alla chiave principale (`hKey`), il nome della sottochiave (`lpSubKey`), e i diritti di accesso richiesti (`samDesired`). Questi parametri permettono alla funzione di creare o aprire una chiave di registro, determinando se la chiave è nuova o già esistente, e se la chiave viene creata, vengono impostati i diritti di accesso e la sicurezza associata. Questo processo è cruciale per manipolare il registro di sistema e garantire l'esecuzione continuativa del codice malevolo, contribuendo al funzionamento persistente del malware.

00401047
push
call
ds:RegSetValueExA

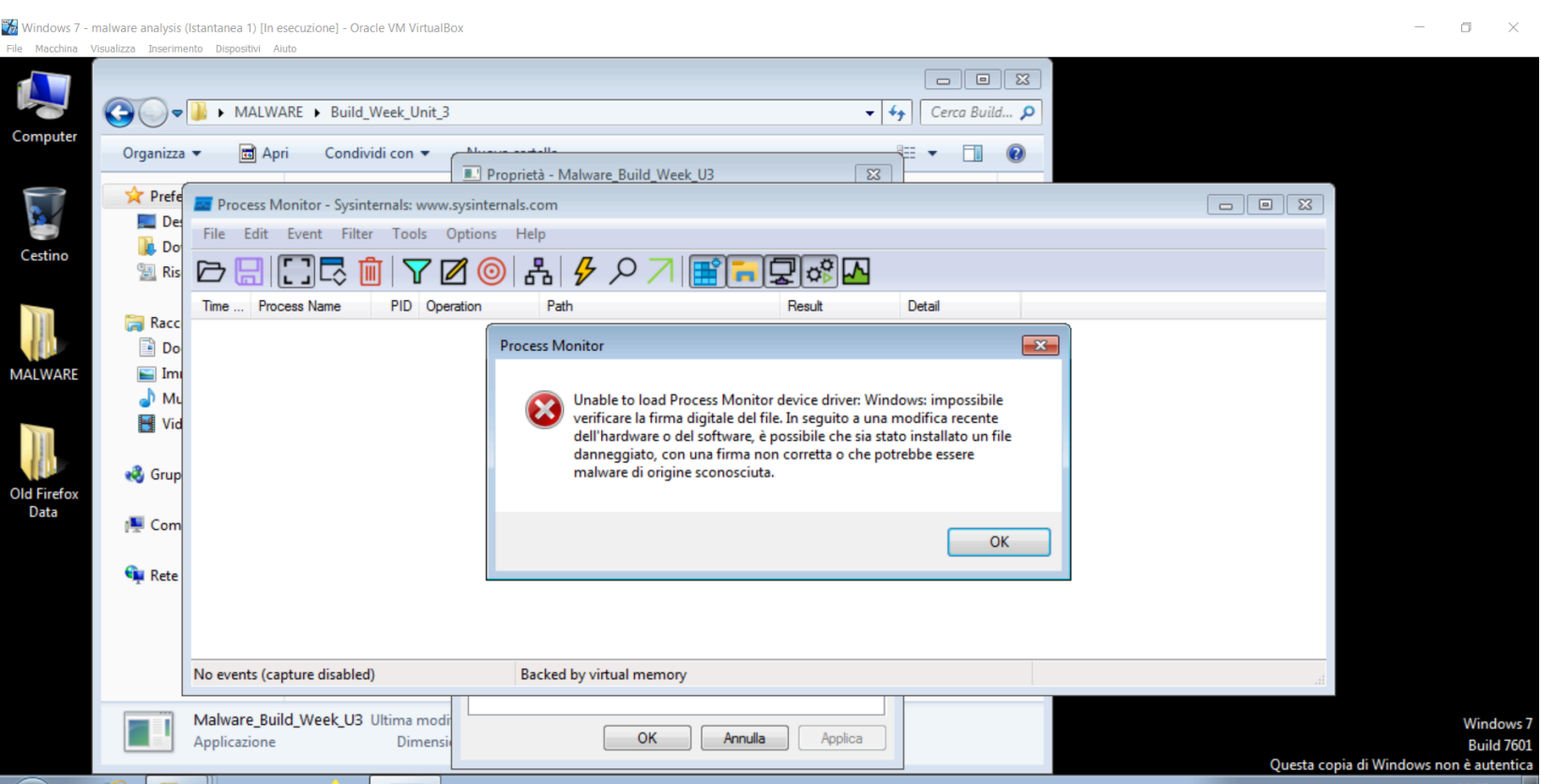
In riferimento alla chiamata alla locazione 00401047, possiamo osservare che essa esegue una chiamata alla funzione RegSetValueExA. Questa funzione fa parte delle API di Windows ed è utilizzata per impostare il valore di una voce all'interno del registro di sistema. Nello specifico, RegSetValueExA permette di associare un valore a una chiave di registro già esistente o creata precedentemente.

Questa funzione è particolarmente utile per modificare configurazioni di sistema o per garantire che un certo software, in questo caso un malware, possa ottenere persistenza nel sistema. Ad esempio, il malware potrebbe utilizzare RegSetValueExA per impostare un valore che fa riferimento a un percorso eseguibile all'interno di una chiave di registro critica, come quelle che determinano i programmi che si avviano automaticamente al login dell'utente. In questo modo, ogni volta che il sistema viene avviato, il codice malevolo verrebbe eseguito automaticamente, senza necessitare di ulteriori interazioni da parte dell'attaccante.

Questa capacità di modificare il registro di sistema, combinata con altre funzioni come RegCreateKeyExA, conferisce al malware un controllo significativo sulle operazioni di startup del sistema operativo, permettendogli di eseguire operazioni malevole su base continuativa e senza rilevamento immediato.

Analisi dinamica con procmon

Quando provo a settare i filtri o a compiere altre azioni su procmon esce un messaggio di errore che non mi fa continuare. Ho cercato per giorni una soluzione (anche provato con un altro file di procmon) ma non sono riuscito a risolvere il problema.



Conclusione

Dall'analisi statica effettuata, il malware in questione sembra essere un programma progettato per introdurre e mantenere componenti dannosi nel sistema compromesso. Le librerie importate e le funzioni utilizzate, come `RegCreateKeyExA` e `RegSetValueExA`, indicano che il malware cerca di ottenere persistenza creando o modificando chiavi di registro, consentendo al codice malevolo di eseguirsi automaticamente ad ogni avvio del sistema. Questo è tipico di malware che punta a stabilirsi in modo duraturo all'interno del sistema operativo.

In aggiunta, la presenza di funzioni come `SizeofResource`, `LockResource`, `LoadResource`, e `FindResourceA` suggerisce che il malware funge anche da veicolo per distribuire ulteriori payload dannosi. Queste API sono utilizzate per localizzare e estrarre un componente nascosto all'interno delle risorse del file eseguibile, che viene poi caricato in memoria e eseguito. Questo metodo serve a immettere e attivare ulteriori elementi malevoli nel sistema target, complicando e intensificando l'attacco.

In sintesi, sulla base dell'analisi statica, possiamo classificare questo malware come un dropper con capacità di persistenza e di distribuzione di componenti aggiuntivi, progettato per assicurare che il codice dannoso rimanga operativo e continui a compromettere il sistema.